

CYBERSECURITY INTERNSHIP

WEEK 3 – NETWORK SECURITY ASSESSMENT

Practical Lab Report

Field	Details
Intern Name	Mah Noor
Program	DG INTERNS HUB
Week	Week 3
Report Title	Network Security Assessment: Nmap & Wireshark
Lab Environment	Kali Linux (Attacker) vs Metasploitable2 (Target)
Submission Deadline	7th September 2026
Date Completed	4th September 2026
Tools Used	Nmap 7.99, Wireshark, Kali Linux, VMware

 All scanning and testing was performed exclusively on an authorized lab environment.

1. Introduction

This report covers Week 3 of the Ubuntu Bridge Initiative (UBI) Cybersecurity Internship. The focus of this week was real-world Network Security Assessment — learning how a professional security analyst discovers hosts, identifies exposed services, analyzes live network traffic, and documents security findings.

The lab was set up using two virtual machines inside VMware on a host-only network: a Kali Linux machine acting as the attacker/analyst, and a Metasploitable2 machine acting as the intentionally vulnerable target.

All scanning, testing, and packet capture was performed only on this private, authorized lab environment.

No external or third-party systems were tested at any point.

2. Objectives

The main objectives for Week 3 were:

- Discover all active hosts in the lab network using Nmap.
- Identify open ports, running services, and their versions on the target machine.
- Capture and analyze live network traffic using Wireshark.
- Correlate Nmap scan results with Wireshark packet captures.
- Perform a vulnerability assessment using Nmap NSE scripts.
- Perform security hardening and verify the changes with before/after scans.
- Document all findings in a professional security assessment report.

3. Lab Environment

The lab was built using VMware with a host-only network (VMnet1 — 192.168.139.0/24). Both virtual machines were isolated from the internet to ensure safe and authorized testing.

Component	Details
Hypervisor	VMware Workstation
Network Type	Host-Only (VMnet1 — 192.168.139.0/24)
Gateway	192.168.139.1
Attacker Machine	Kali Linux — 192.168.139.128
Target Machine	Metasploitable2 — 192.168.139.129
Nmap Version	7.99
Wireshark	Latest (capturing on eth0)

The network diagram below shows how both machines are connected through the VMware host-only

network.

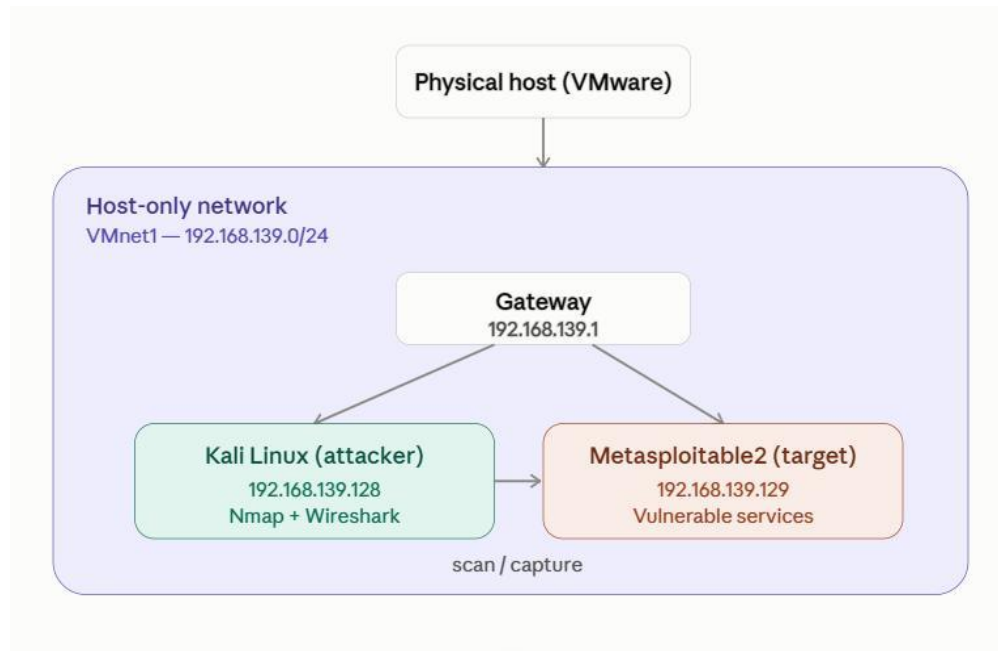


Figure 1: Lab Network Topology — Kali Linux (Attacker) ↔ Metasploitable2 (Target)

4. Tools Used

Tool	Purpose	Version
Nmap	Network discovery, port scanning, service detection, vulnerability scripts	7.99
Wireshark	Live packet capture and traffic analysis	Latest
Kali Linux	Attacker/analyst operating system	Rolling
Metasploitable2	Intentionally vulnerable target OS	2.0
VMware	Virtualization platform for isolated lab	Workstation

5. Task 7 – Network Discovery & Basic Nmap Scanning

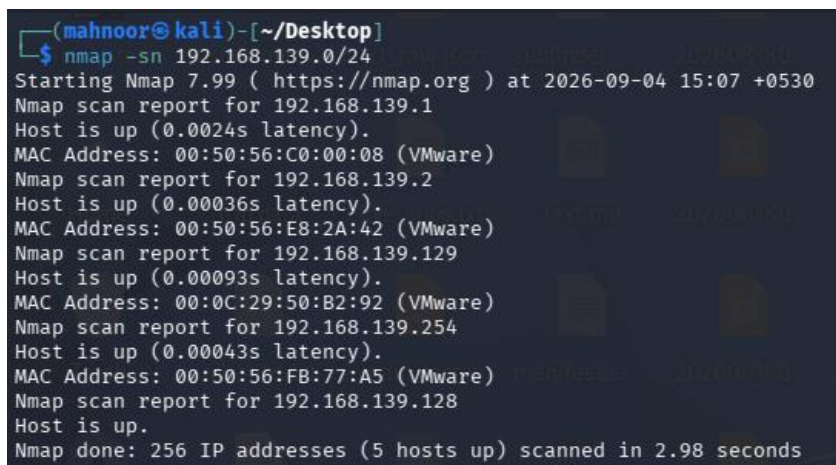
5.1 What is Network Discovery?

Network discovery is the first step in any security assessment. Before testing anything, a security analyst needs to know which devices are active on the network. The tool used for this is Nmap (Network Mapper), which sends packets to a range of IP addresses and checks which ones respond.

5.2 Host Discovery Scan

The `-sn` flag tells Nmap to do a "ping scan" — it checks which hosts are alive without scanning any ports. The command used was:

```
nmap -sn 192.168.139.0/24
```



```
(mahnoor@kali)-[~/Desktop]
$ nmap -sn 192.168.139.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 15:07 +0530
Nmap scan report for 192.168.139.1
Host is up (0.0024s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.139.2
Host is up (0.00036s latency).
MAC Address: 00:50:56:E8:2A:42 (VMware)
Nmap scan report for 192.168.139.129
Host is up (0.00093s latency).
MAC Address: 00:0C:29:50:B2:92 (VMware)
Nmap scan report for 192.168.139.254
Host is up (0.00043s latency).
MAC Address: 00:50:56:FB:77:A5 (VMware)
Nmap scan report for 192.168.139.128
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.98 seconds
```

Figure 2: Nmap host discovery scan — 5 active hosts found in 192.168.139.0/24

5.3 Discovery Results

The scan found 5 active hosts in the /24 subnet. The two key machines for this lab were:

IP Address	Role	MAC Address	Vendor
192.168.139.128	Kali Linux – Attacker/Analyst	00:50:56:E8:2A:42	VMware
192.168.139.129	Metasploitable2 – Target	00:0C:29:50:B2:92	VMware
192.168.139.1	Gateway	00:50:56:C0:00:08	VMware
192.168.139.254	VMware DHCP/NAT	00:50:56:FB:77:A5	VMware

5.4 Basic Port Scan on Target

After confirming which hosts are active, a basic scan was run on the target (Metasploitable2) to get the list of open ports:

```
nmap -sV 192.168.139.129
```

```

(mahnoor@kali) - [~/Desktop]
$ nmap -sV 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 15:08 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql           MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)

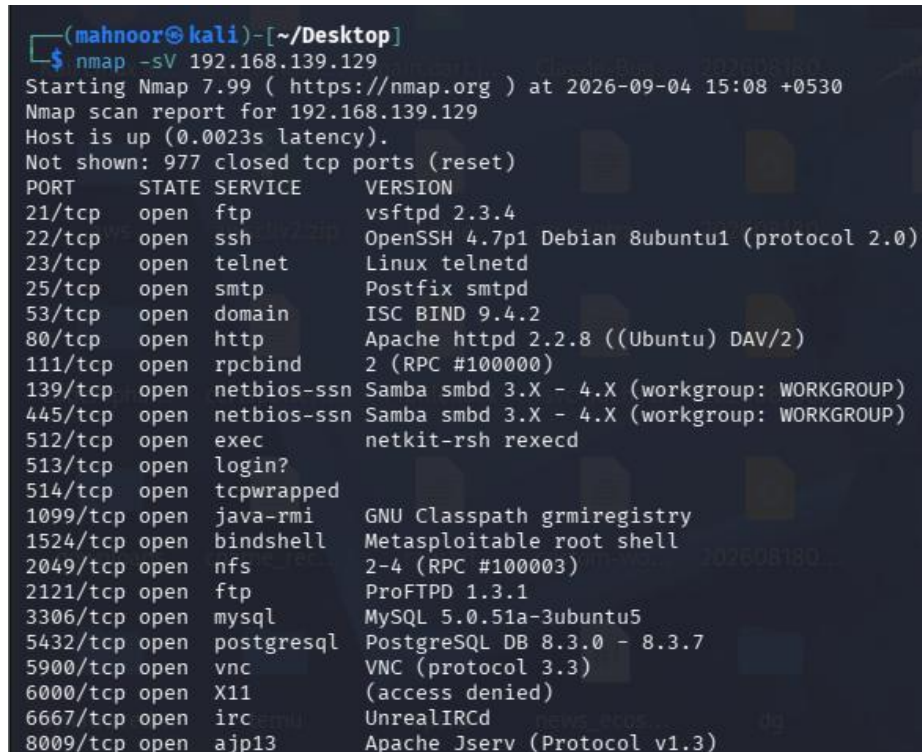
```

Figure 3: nmap -sV result showing open ports and service versions on Metasploitable2

6. Task 8 – Advanced Nmap Security Assessment

6.1 Service & Version Detection (-sV)

The -sV flag makes Nmap probe each open port to determine what service is running and what version. This is very useful for identifying outdated or vulnerable software.



```
(mahnoor@kali) - [~/Desktop]
$ nmap -sV 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 15:08 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
```

Figure 4: Detailed service version detection on Metasploitable2

6.2 Aggressive Scan (-A)

The -A flag combines OS detection, version detection, script scanning, and traceroute. It gives a much deeper picture of the target.

```
nmap -A 192.168.139.129
```

```

(mahnoor@kali)-[~/Desktop]
$ nmap -A 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 15:08 +0530
Nmap scan report for 192.168.139.129
Host is up (0.00093s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.139.128
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:c1:c0:5f:6a:7d:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-command: metaspoitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-09-04T09:39:01+00:00; +7s from scanner time.
27/tcp    open  domain

```

Figure 5: Aggressive scan — shows FTP anon login allowed, SSH keys, SSL ciphers

6.3 SYN Scan (-sS)

The -sS (SYN scan) is also called a "half-open" or "stealth" scan. Nmap sends a SYN packet and waits for SYN/ACK (open) or RST (closed) without completing the full TCP handshake. It is faster and harder to detect than a full connect scan.

```
sudo nmap -sS 192.168.139.129
```

```

(mahnoor@kali)-[~/Desktop]
$ sudo nmap -sS 192.168.139.129
[sudo] password for mahnoor:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 16:14 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:50:B2:92 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.03 seconds

```

Figure 6: TCP SYN scan result — all open ports on Metasploitable2

6.4 Complete Port & Service Summary Table

The table below summarizes all open ports found on the target machine (192.168.139.129 — Metasploitable2), along with risk classification and security observations:

Port	Protocol	Service	Version	Risk	Observation
21	TCP	FTP	vsFTPd 2.3.4	CRITICAL	Known backdoor CVE-2011-2523. Anonymous login allowed.
22	TCP	SSH	OpenSSH 4.7p1	Medium	Remote access service. Old version may have vulnerabilities.
23	TCP	Telnet	Linux telnetd	High	Unencrypted protocol. Credentials sent in plain text.
25	TCP	SMTP	Postfix smtpd	Medium	Mail service exposed. Could be used for spam relaying.
53	TCP	DNS	ISC BIND 9.4.2	Medium	Old DNS version. Potential zone transfer vulnerability.
80	TCP	HTTP	Apache 2.2.8	High	Web server exposed with old version. Multiple CVEs known.
111	TCP	RPCbind	v2 RPC #100000	Medium	RPC service exposed. Can enumerate NFS shares.
139/445	TCP	Samba	Samba 3.x-4.x	High	Windows file sharing. Old Samba versions are exploitable.
512-514	TCP	rexec/rlogin	netkit-rsh	Critical	Legacy r-services. No encryption, easily abused.
1099	TCP	Java RMI	GNU Classpath	High	Remote code execution risk via RMI deserialization.
1524	TCP	Bindshell	Metasploitable shell	CRITICAL	Open backdoor shell — gives root access instantly.
2049	TCP	NFS	2-4 RPC #100003	High	Network file system exposed — data leakage risk.
3306	TCP	MySQL	5.0.51a	High	Database exposed to network. Outdated MySQL version.
5432	TCP	PostgreSQL	8.3.0-8.3.7	High	Database exposed. Old version with known vulnerabilities.
5900	TCP	VNC	Protocol 3.3	High	Remote desktop exposed. Weak authentication risk.
6000	TCP	X11	Access denied	Medium	Display server exposed on network.
6667	TCP	IRC	UnrealIRCd	CRITICAL	UnrealIRCd backdoor — known remote code execution.
8009	TCP	AJP	Apache Jserv	High	AJP connector exposed — Ghostcat vulnerability risk.
8180	TCP	HTTP	Tomcat/Coyote	High	Tomcat exposed with default credentials risk.

6.5 Advanced Analysis — Key Services

For the most critical services, here is a detailed analysis:

Port 21 — FTP (vsFTPD 2.3.4) — CRITICAL

Service Running: vsftpd 2.3.4 FTP server. This specific version contains a deliberate backdoor that was inserted by an attacker who compromised the official vsftpd download server in 2011.

Why Exposed: FTP is used for file transfer. However, in this version, anonymous login is also enabled, meaning anyone can connect without a password.

Is It Necessary: No. FTP is an insecure protocol even without the backdoor. Secure alternatives like SFTP or SCP should be used.

What Could Happen: An attacker sends a specially crafted FTP username and gets a root shell on port 6200. This is a complete system takeover.

How to Secure: Disable vsftpd immediately. Replace with SFTP. Never use this version of vsftpd.

Port 23 — Telnet — HIGH

Service Running: Linux telnetd — a plain-text remote access protocol.

Why Exposed: Telnet was the predecessor to SSH for remote server management.

Is It Necessary: No. SSH replaces Telnet completely and provides encryption.

What Could Happen: Any attacker who can see the network traffic (man-in-the-middle) can read usernames and passwords in plain text using Wireshark.

How to Secure: Disable Telnet. Use SSH only.

Port 1524 — Bindshell (Root Backdoor) — CRITICAL

Service Running: Metasploitable root shell — this is an intentional backdoor in the lab. Connecting to port 1524 immediately gives a root shell.

Is It Necessary: Absolutely not. This should never exist on any real system.

What Could Happen: Instant complete system takeover by any user who connects to this port.

How to Secure: Kill the process and block this port in the firewall.

7. Task 9 – Wireshark Network Traffic Capture

Wireshark was used to capture live network traffic on the eth0 interface while various activities were performed — pinging the target, accessing web services, and running Nmap scans. The capture file is saved as `wireshark_eth0RW77U3.pcapng`.

7.1 DNS Traffic Analysis

DNS (Domain Name System) translates domain names into IP addresses. DNS queries show what websites or services a machine is trying to reach. The filter used was: dns

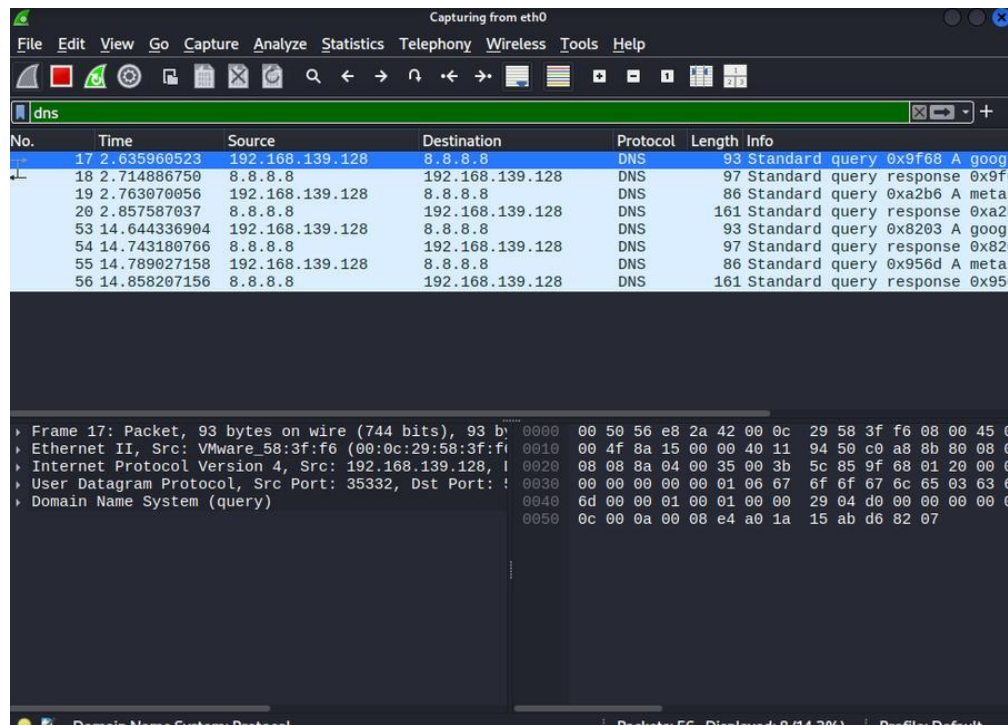


Figure 7: DNS traffic — Wireshark filter "dns" shows queries from 192.168.139.128 to 8.8.8.8 (Google DNS)

Observation: The Kali machine (192.168.139.128) was making DNS queries to 8.8.8.8 (Google's public DNS server). The queries included lookups for google.com and metasploitable.localdomain. This is normal traffic showing the machine's DNS resolution activity.

7.2 TCP Traffic Analysis

TCP (Transmission Control Protocol) is the main protocol used for reliable connections like web browsing and file transfer. Filter used: tcp

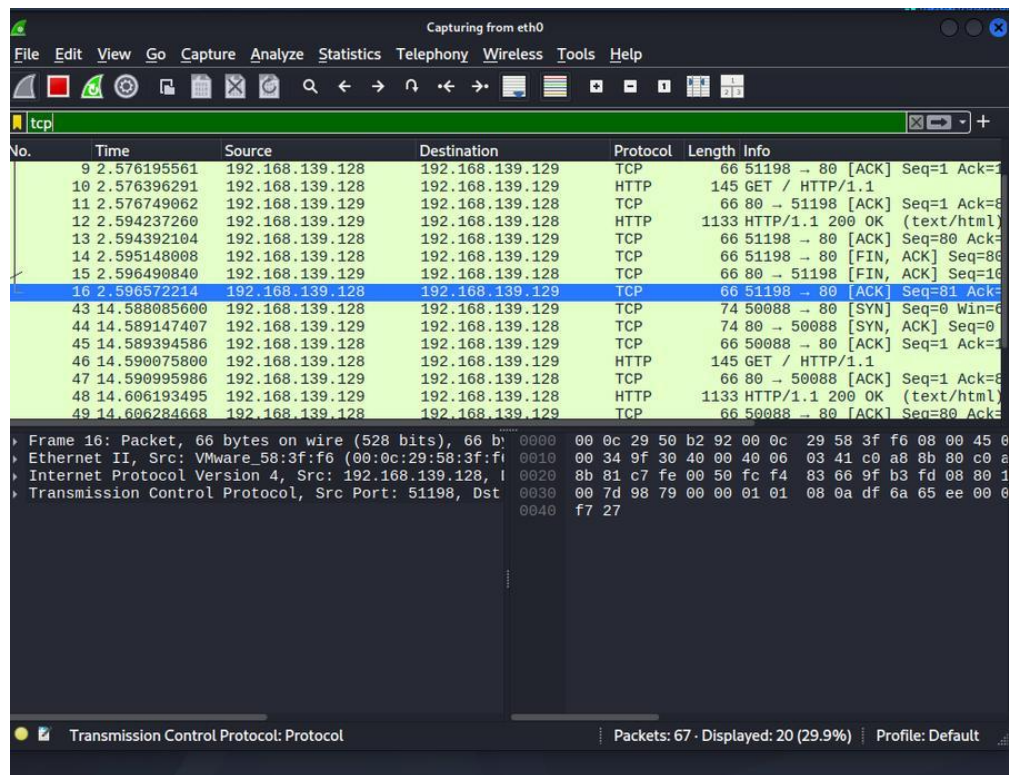


Figure 8: TCP traffic showing HTTP connections — three-way handshake visible (SYN, SYN/ACK, ACK)

Observation: The Kali machine was making HTTP connections to the Metasploitable2 web server on port 80. The full TCP three-way handshake (SYN → SYN/ACK → ACK) was clearly visible, followed by a GET / HTTP/1.1 request and a 200 OK response.

7.3 ICMP Traffic (Ping)

ICMP Echo (ping) packets were captured while pinging the target machine. Filter used: icmp

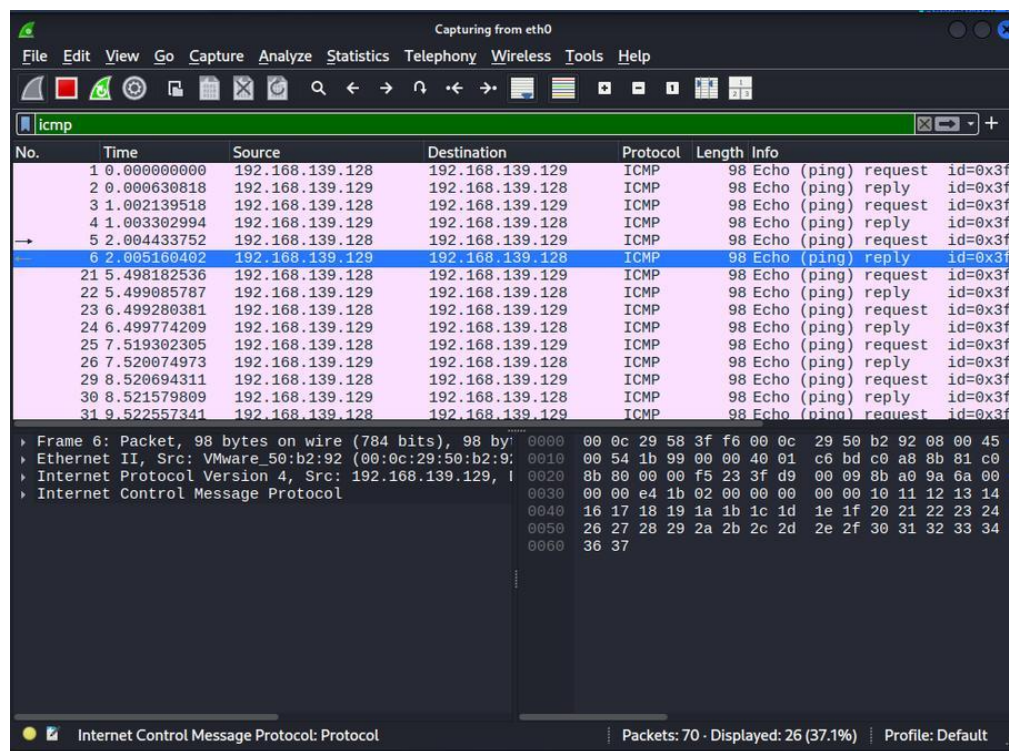


Figure 9: ICMP ping traffic — Echo request and reply between Kali and Metasploitable2

Observation: Regular ping traffic was observed between 192.168.139.128 (Kali) and 192.168.139.129 (Metasploitable2). Each ping request (Echo) received a reply, confirming the host is alive and reachable. ICMP traffic can be used by attackers for host discovery.

7.4 TCP SYN Flag Filter

To isolate only SYN packets (the start of TCP connections), the following filter was used: `tcp.flags.syn == 1`

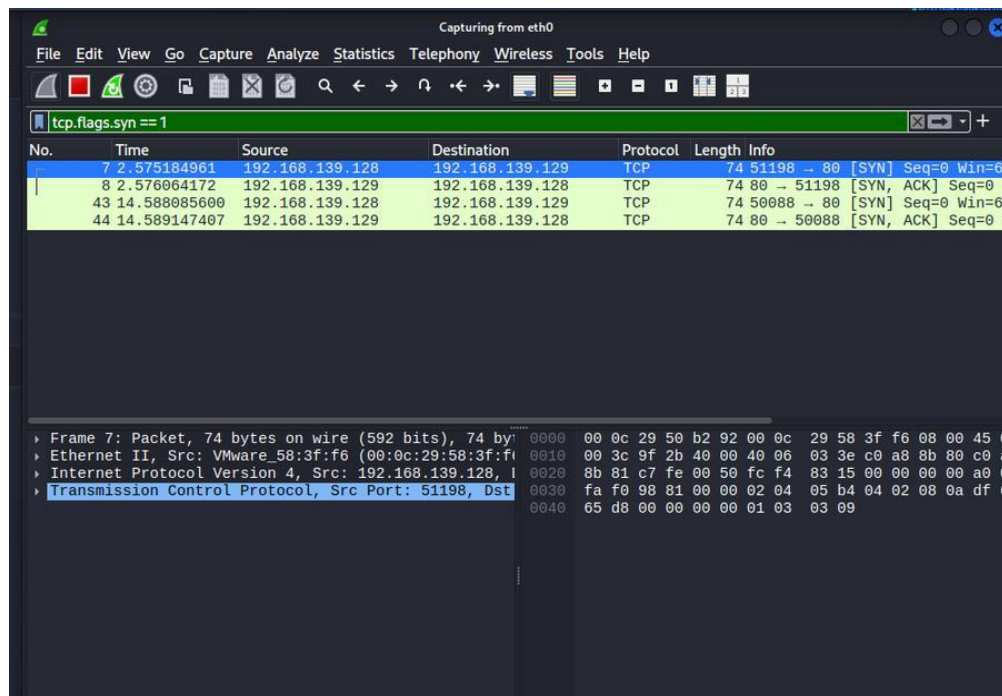


Figure 10: SYN packets only — shows new connection attempts being initiated

7.5 Nmap Scan Packets Visible in Wireshark

After running a SYN scan from Kali (nmap -sS 192.168.139.129), the scan packets were visible in Wireshark.

Filter used: `ip.addr == 192.168.139.129 && tcp.flags.syn == 1`

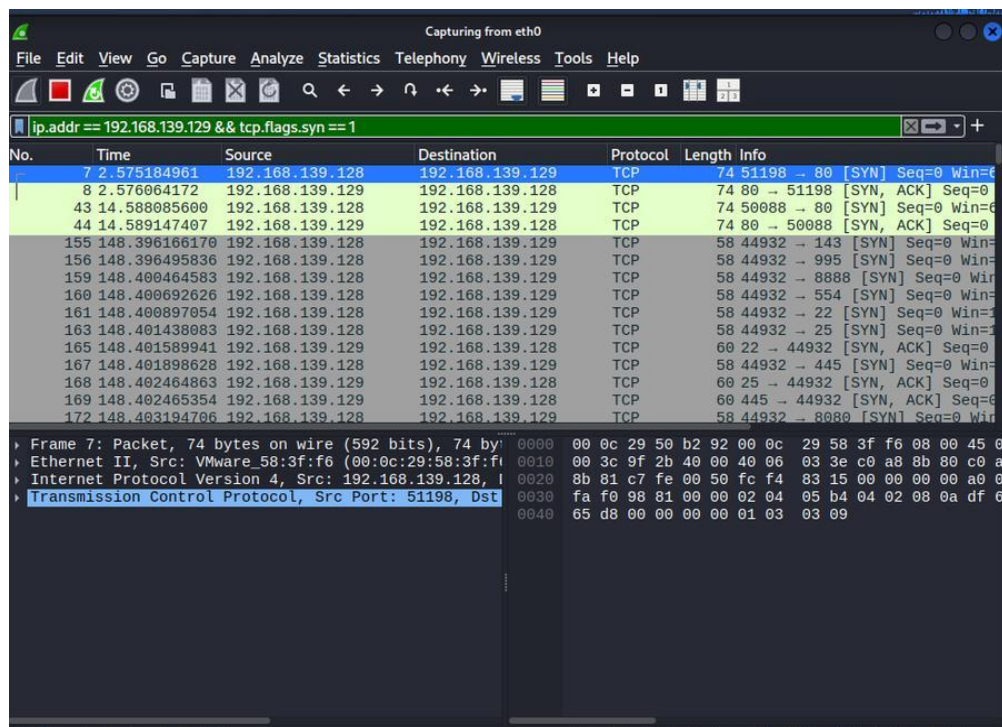


Figure 11: Wireshark showing Nmap scan — many SYN packets to different destination ports

7.6 Conversation Statistics

Wireshark's Statistics > Conversations shows the total communication between two hosts. The Ethernet tab showed one major conversation between the two VMware MACs — 1,027 packets / 60 KB over 2,072 total packets.

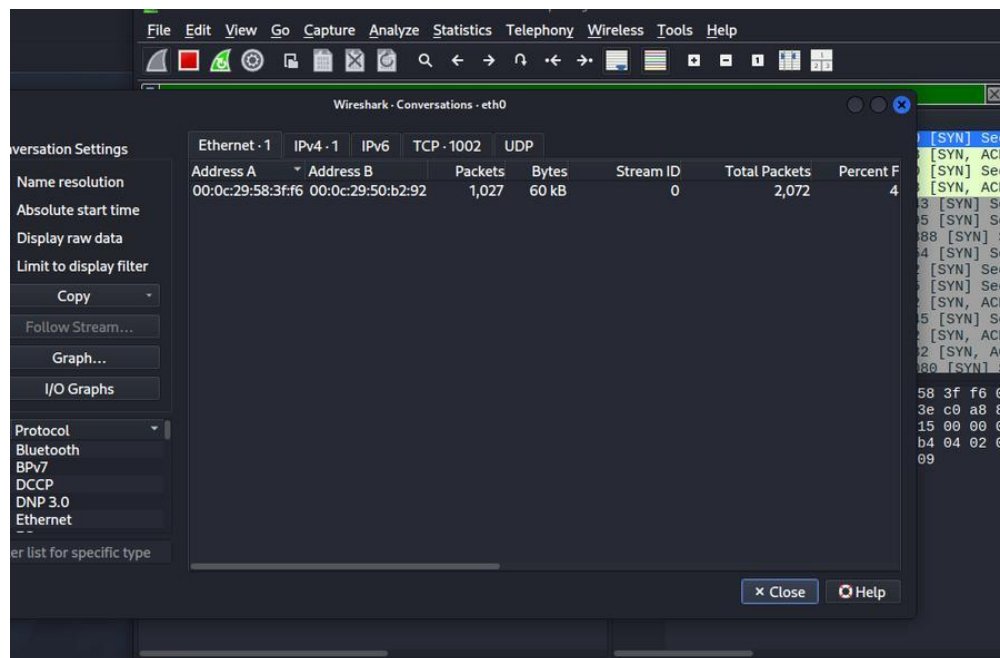


Figure 12: Wireshark Conversations — showing the single Ethernet conversation in the lab

8. Task 10 – Nmap + Wireshark Investigation

This task involved running an Nmap scan while Wireshark was capturing, then looking at the packets to understand exactly what Nmap does at the packet level. This is very useful for understanding how port scanning actually works.

8.1 SYN-Only Packets

Filter: `tcp.flags.syn == 1 && tcp.flags.ack == 0` — This shows only the initial SYN packets sent by Nmap to probe ports.

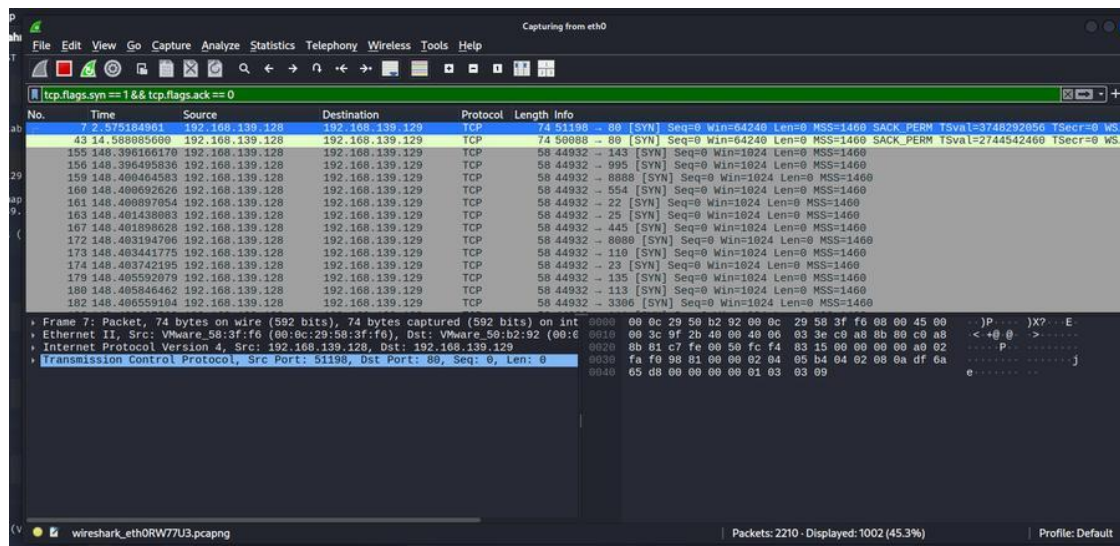


Figure 13: Nmap SYN packets to multiple destination ports — port scanning visible at packet level

Observation: Nmap sent SYN packets to ports 80, 143, 995, 8888, 554, 22, 25, 445, 8080, 110, 23, 135, and many others. Each one probes a different port to check if it is open.

8.2 RST Packets (Closed Ports)

Filter: `tcp.flags.reset == 1` — These RST (Reset) packets come from the target for ports that are closed.

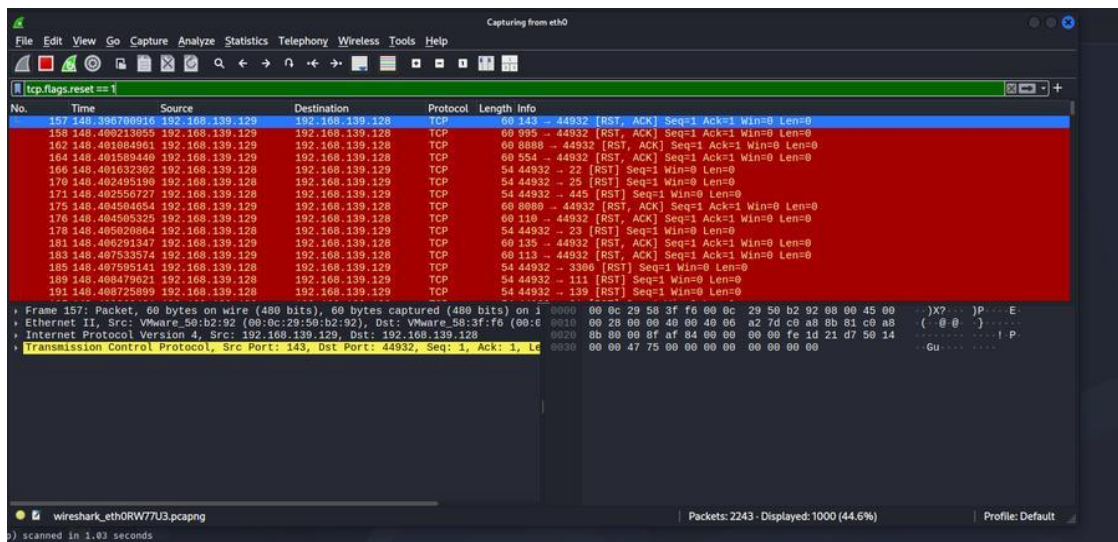


Figure 14: RST packets — target refusing connections on closed ports (highlighted in red)

8.3 Nmap vs Wireshark Comparison Table

Nmap Result	Wireshark Evidence	Interpretation
Port 80 — Open	SYN from Kali → SYN/ACK from target	Web server is running and accepting connections
Port 22 — Open	SYN from Kali → SYN/ACK from target	SSH service is active and responding
Port 143 — Closed	SYN from Kali → RST from target	IMAP port is not in use, target immediately rejects
Port 995 — Closed	SYN from Kali → RST from target	POP3S port is closed, no service running
Port 8888 — Closed	SYN from Kali → RST from target	No service on port 8888
Port 21 — Open	SYN from Kali → SYN/ACK from target	FTP backdoor (vsftpd 2.3.4) is active
Port 1524 — Open	SYN from Kali → SYN/ACK from target	Root bindshell backdoor is active and responding

8.4 Conclusion from Task 10

This exercise proved that Nmap's port scan results can be fully verified at the packet level in Wireshark. An open port produces a SYN/ACK response from the target. A closed port produces a RST response. This understanding is essential for both offense (pentesting) and defense (IDS tuning, firewall rule writing).

9. Task 11 – Advanced Network Traffic Investigation

A deeper investigation was conducted on the captured pcapng file. The total capture contained 2,210 packets (2,243 after the full scan). This section documents the most significant findings.

9.1 Top Communicating Hosts

IP Address	Role	Traffic Direction	Observation
192.168.139.128	Kali Linux (Attacker)	Source of most scans	Generated SYN floods during Nmap scans
192.168.139.129	Metasploitable2 (Target)	Destination of all scans	Responded with SYN/ACK (open) or RST (closed)
8.8.8.8	Google DNS	DNS query destination	DNS resolution traffic observed from Kali

9.2 Suspicious Activity Investigation Table

Time (s)	Source IP	Dest IP	Port	Protocol	Observation	Security Significance
2.575	192.168.139.128	192.168.139.129	80	TCP	SYN — port scan probe	Start of Nmap SYN scan — reconnaissance activity
148.396	192.168.139.128	192.168.139.129	143, 995, 8888	TCP	Multiple SYN packets to closed ports	Nmap scanning across port range — 1002 SYN packets
148.396	192.168.139.129	192.168.139.128	143	TCP	RST/ACK — port closed	Target rejecting closed port connections
2.635	192.168.139.128	8.8.8.8	53	DNS	DNS query for google.com	Normal DNS lookup — no threat
2.714	8.8.8.8	192.168.139.128	53	DNS	DNS response	DNS response received — normal
2.576	192.168.139.128	192.168.139.129	80	HTTP	GET / HTTP/1.1	HTTP web request to Apache server
2.594	192.168.139.129	192.168.139.128	80	HTTP	HTTP 200 OK (text/html)	Apache returned the web page successfully
0.000	192.168.139.128	192.168.139.129		ICMP	Echo (ping) request	Host discovery ping — attacker checking if target is alive
0.000	192.168.139.129	192.168.139.128		ICMP	Echo (ping) reply	Target confirmed alive and reachable
148.402	192.168.139.128	192.168.139.129	445	TCP	SYN to Samba port	Nmap probing Samba — potential SMB enumeration

9.3 Key Observation

The most significant pattern observed was a large burst of TCP SYN packets from 192.168.139.128 to 192.168.139.129 starting at around timestamp 148 seconds. This is the unmistakable signature of a TCP SYN port scan. In a real network, this pattern would trigger an IDS (Intrusion Detection System) alert for "Port

Scan Detected."

The RST responses (shown in red in Wireshark) confirm which ports were closed. The SYN/ACK responses (shown in green) confirm open ports, which matched the Nmap results exactly.

10. Task 12 – Vulnerability Assessment

Based on all evidence gathered from Tasks 7–11, the following security findings were identified on the Metasploitable2 target:

#	Finding	Evidence	Risk	Potential Impact	Recommendation
1	vsFTPD 2.3.4 Backdoor (CVE-2011-2523)	Port 21 open, nmap --script vuln confirmed VULNERABLE	CRITICAL	Remote attacker gets a root shell on port 6200 without any credentials. Complete system takeover.	Immediately disable and remove vsftpd 2.3.4. Replace with SFTP (OpenSSH).
2	Bindshell Backdoor on Port 1524	Port 1524 open — service labeled "Metasploitable root shell"	CRITICAL	Any user connecting to port 1524 gets an immediate root shell. No authentication required.	Kill the bindshell process. Block port 1524 in firewall. Audit system for other backdoors.
3	UnrealIRCd Backdoor (Port 6667)	Port 6667 open — UnrealIRCd confirmed by nmap -sV	CRITICAL	UnrealIRCd had a known backdoor allowing remote command execution as the server process user.	Disable IRC service. Remove UnrealIRCd. Block port 6667 in firewall.
4	Telnet Service Exposed (Port 23)	Port 23 open — Linux telnetd confirmed. Data visible in Wireshark as plain text.	High	All usernames and passwords sent over Telnet are visible in plain text to anyone capturing network traffic.	Disable Telnet service. Use SSH exclusively for remote access.
5	r-services Exposed (Ports 512-514)	Ports 512 (rexec), 513 (rlogin), 514 (rsh) all open	Critical	Legacy r-services have no encryption and use weak host-based authentication. Easily abused for lateral movement.	Disable all r-services (rexec, rlogin, rsh). Replace with SSH.
6	Anonymous FTP Login Allowed	nmap -A confirmed: ftp-anon: Anonymous FTP login allowed	High	Anyone can connect to FTP without a password and potentially read or write files on the server.	Disable anonymous FTP. Require authentication. Switch to SFTP.
7	Outdated Database Servers Exposed	MySQL 5.0.51a (port 3306), PostgreSQL 8.3.0 (port 5432) both open to network	High	Old database versions with known CVEs. Database exposed directly on network without firewall restriction.	Update to current versions. Bind databases to 127.0.0.1 only. Use firewall rules.
8	SSL POODLE Vulnerability (CVE-2014-3566)	nmap --script ssl-poodle VULNERABLE on port 25	High	SSLv3 POODLE attack allows man-in-the-middle attacker to decrypt encrypted communications.	Disable SSLv3. Use TLS 1.2 or higher only. Update OpenSSL.

#	Finding	Evidence	Risk	Potential Impact	Recommendation
9	VNC Remote Desktop Exposed (Port 5900)	Port 5900 open — VNC Protocol 3.3	High	Remote desktop exposed to entire network. Old VNC protocol 3.3 has weak authentication.	Restrict VNC to localhost only. Use VPN or SSH tunnel. Upgrade VNC version.
10	NFS Shares Potentially Exposed (Port 2049)	Port 2049 open — NFS 2-4 confirmed	High	NFS shares might be world-readable or world-writable, allowing unauthorized file access or data modification.	Audit NFS exports. Restrict to specific IPs. Disable if not needed.

10.1 Vulnerability Scan — Nmap NSE Scripts

Nmap has built-in vulnerability detection scripts that can be run using the `--script vuln` flag. This was run against the target to confirm known CVEs:

```
sudo nmap --script vuln 192.168.139.129
```

```
(mahnoor@kali) [~/Desktop]
$ sudo nmap --script vuln 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 16:19 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523 BID:48539
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|       State: VULNERABLE
|       IDs: CVE:CVE-2014-3566 BID:70574
|       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|       products, uses nondeterministic CBC padding, which makes it easier
|       for man-in-the-middle attackers to obtain cleartext data via a
|       padding-oracle attack, aka the "POODLE" issue.
|       Disclosure date: 2014-10-14
|       Check results:
|         TLS_RSA_WITH_AES_128_CBC_SHA
|       References:
```

Figure 15: `nmap --script vuln` confirms vsFTPD 2.3.4 backdoor (CVE-2011-2523) and SSL POODLE (CVE-2014-3566)

11. Task 13 – Security Hardening & Before/After Testing

After identifying vulnerabilities, three security improvements were implemented on the Metasploitable2 machine. Each change was verified with a before and after Nmap scan from the Kali machine.

11.1 Hardening Action 1 — Disable vsFTPD (Port 21)

BEFORE Hardening

Port 21 was open and the vsFTPD 2.3.4 backdoor was active and exploitable.

```
(mahnoor@kali) - [~/Desktop]
$ nmap -sV 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 15:08 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
```

Figure 16: BEFORE — Port 21 open with vsFTPD 2.3.4 (backdoor active)

Actions Taken on Metasploitable2

The FTP service was stopped by finding and killing the vsftpd/xinetd process:

```
sudo netstat -tulnp | grep :21 sudo kill -9 5019 sudo netstat -tulnp | grep -E ':21|:23'
```

```

bootmisc.sh      mysql      skeleton
checkfs.sh       mysql-ndb  ssh
checkroot.sh     mysql-ndb-mgm stop-bootlogd
console-screen.sh networking stop-bootlogd-single
console-setup    nfs-common sysklogd
cron             nfs-kernel-server tomcat5.5
distcc          openbsd-inetd udev
dns-clean       pcmciautils udev-finish
glibc.sh        portmap    ufw
halt            postfix    umountfs
hostname.sh     postgresql-8.3 umountnfs.sh
hwclockfirst.sh pppd-dns   umountroot
hwclock.sh      procps     urandom
keyboard-setup  proftpd    waitnfs.sh
killprocs       rc         wpa-ifupdown
klogd           rc.local   x11-common
loopback        rcS        xinetd
module-init-tools README      xserver-xorg-input-wacom
mountall-bootclean.sh reboot
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep :21
tcp        0      0 0.0.0.0:21          0.0.0.0:*        LISTEN
5019/xinetd
tcp6       0      0 :::2121            :::*              LISTEN
5058/proftpd: (acce
msfadmin@metasploitable:~$ sudo kill

```

Figure 17: Killing the FTP/xinetd process — port 21 process found and terminated

```

cron            nfs-kernel-server tomcat5.5
distcc          openbsd-inetd     udev
dns-clean       pcmciautils   udev-finish
glibc.sh        portmap          ufw
halt            postfix         umountfs
hostname.sh     postgresql-8.3   umountnfs.sh
hwclockfirst.sh pppd-dns         umountroot
hwclock.sh      procps           urandom
keyboard-setup  proftpd          waitnfs.sh
killprocs       rc              wpa-ifupdown
klogd           rc.local        x11-common
loopback        rcS             xinetd
module-init-tools README      xserver-xorg-input-wacom
mountall-bootclean.sh reboot
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep :21
tcp        0      0 0.0.0.0:21          0.0.0.0:*        LISTEN
5019/xinetd
tcp6       0      0 :::2121            :::*              LISTEN
5058/proftpd: (acce
msfadmin@metasploitable:~$ sudo kill -9 5019
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep -E ':21:23'
tcp6       0      0 :::2121            :::*              LISTEN
5058/proftpd: (acce
msfadmin@metasploitable:~$ _

```

Figure 18: After kill — port 21 confirmed no longer listening, port 23 also removed

```

5019/xinetd
tcp6      0      0 :::2121          :::*             LISTEN
5058/proftpd: (acce
msfadmin@metasploitable:~$ sudo kill -9 5019
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep -E ':21::23'
tcp6      0      0 :::2121          :::*             LISTEN
5058/proftpd: (acce
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep :1099
tcp       0      0 0.0.0.0:1099      0.0.0.0:*        LISTEN
5152/rmiregistry
msfadmin@metasploitable:~$ sudo kill -9 5152
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep -E ':21::23::1099'
tcp6      0      0 :::2121          :::*             LISTEN
5058/proftpd: (acce
msfadmin@metasploitable:~$ nmap -p 21,23,1099 192.168.139.129

Starting Nmap 4.53 ( http://insecure.org ) at 2026-09-04 07:31 EDT
Interesting ports on 192.168.139.129:
PORT      STATE SERVICE
21/tcp    closed ftp
23/tcp    closed telnet
1099/tcp  closed unknown

Nmap done: 1 IP address (1 host up) scanned in 0.108 seconds
msfadmin@metasploitable:~$

```

Figure 19: Further verification — ports 21, 23, 1099 all closed after killing processes

AFTER Hardening

```

(mahnoor@kali)-[~/Desktop]
$ nmap -p 21,23,1099 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 17:03 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0011s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
23/tcp    closed telnet
1099/tcp  closed rmiregistry
MAC Address: 00:0C:29:50:B2:92 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.79 seconds

```

Figure 20: AFTER — Nmap confirms ports 21 (FTP), 23 (Telnet), 1099 (Java RMI) all CLOSED

11.2 Hardening Action 2 — Disable Telnet (Port 23)

Telnet was disabled as part of the same xinetd process kill (since xinetd managed both FTP and Telnet on Metasploitable2). The after scan confirmed port 23 was closed.

Security Issue	Before	Action Taken	After	Improvement
vsFTPD 2.3.4 Backdoor — Port 21	OPEN — CRITICAL CVE-2011-2523 active	Killed xinetd process (PID 5019) managing vsftpd	CLOSED — port 21 no longer responding	Critical backdoor eliminated
Telnet Service — Port 23	OPEN — plain text credentials, HIGH risk	Killed xinetd process (same PID as FTP)	CLOSED — port 23 no longer responding	Unencrypted remote access eliminated
Java RMI — Port 1099	OPEN — RMI deserialization risk, HIGH	Killed rmiregistry process (PID 5152)	CLOSED — port 1099 no longer responding	Remote code execution vector removed

11.3 Final Verification Scan

After all hardening steps, a fresh nmap -sV scan was run from Kali to confirm the current state of the target:

```
(mahnoor@kali) ~/Desktop
$ nmap -sV 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 17:04 +0530
Nmap scan report for 192.168.139.129
Host is up (0.0012s latency).
Not shown: 984 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:50:B2:92 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Linux, Unix; CPE: cpe:/o:linux:linux_kernel
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.77 seconds
```

Figure 21: Final verification scan — ports 21, 23, 1099 confirmed CLOSED after hardening

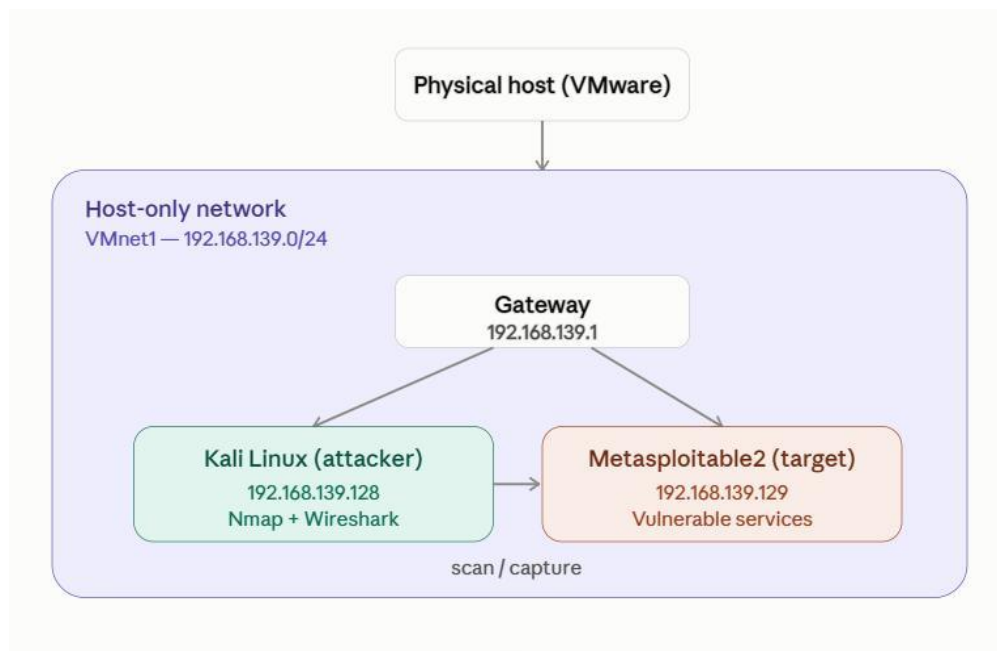


Figure 22: Lab topology reference — Kali attacking/hardening Metasploitable2 in host-only network

12. Task 14 – Final Mini Security Assessment

12.1 Network Discovery Summary

Question	Answer
Devices identified?	5 hosts — Gateway (192.168.139.1), Kali (192.168.139.128), Metasploitable2 (192.168.139.129), VMware DHCP (192.168.139.254)
Services exposed?	20+ open ports on Metasploitable2 including FTP, SSH, Telnet, SMTP, HTTP, Samba, MySQL, PostgreSQL, VNC, IRC, Bindshell, and more

12.2 Traffic Analysis Summary

Question	Answer
Protocols observed?	DNS, TCP, UDP, ICMP, HTTP, ARP — all captured and analyzed in Wireshark
Communication patterns?	Normal ping/DNS traffic, HTTP web requests, and a large TCP SYN scan pattern (1,002 SYN packets) from Kali to Metasploitable2

12.3 Security Assessment Summary

Question	Answer
Major findings?	3 CRITICAL backdoors (vsftpd, bindshell, UnrealIRCd), 1 confirmed CVE (POODLE), multiple outdated services, Telnet, anonymous FTP, exposed databases
Highest risk findings?	Port 1524 (root bindshell), Port 21 (vsFTPd backdoor), Port 6667 (UnrealIRCd backdoor) — all give immediate unauthorized root access
Supporting evidence?	Nmap -sV, -A, --script vuln screenshots, Wireshark packet captures, before/after scans

12.4 Hardening Summary

Question	Answer
Improvements made?	Port 21 (FTP backdoor) closed, Port 23 (Telnet) closed, Port 1099 (Java RMI) closed — all verified with after scans
What changed?	3 high-risk ports moved from OPEN to CLOSED. Attack surface reduced by eliminating 3 known vulnerable services.
Attack surface reduced?	Yes — 3 critical/high attack vectors eliminated. Further hardening recommended for remaining open ports.

13. Security Recommendations

Based on the complete Week 3 assessment, the following 5 professional security recommendations are made for this lab network (and apply equally to any real-world environment):

Recommendation 1: Apply the Principle of Least Privilege for Network Services

Every service that is not absolutely necessary should be disabled. Metasploitable2 had 20+ open ports, many of which serve no practical purpose. Each open port is an additional attack surface. A security rule to follow: "If you do not need it, disable it." Close all unnecessary ports. Run the minimum number of services needed for the system's purpose.

Recommendation 2: Replace All Unencrypted Protocols

Telnet (port 23) and FTP (port 21) transmit all data — including passwords — in plain text. Wireshark can capture and read these credentials in seconds. Replace Telnet with SSH. Replace FTP with SFTP or SCP. Disable all r-services (rlogin, rexec, rsh). Encrypt all remote access.

Recommendation 3: Keep All Software Updated and Patched

Metasploitable2 runs extremely old versions of software: Apache 2.2.8 (2008), MySQL 5.0.51a (2007), OpenSSH 4.7p1 (2007), PostgreSQL 8.3. All of these have known CVEs. A proper patch management program should keep software up to date. Subscribe to CVE feeds and security advisories for all software in use.

Recommendation 4: Implement Network Segmentation and Firewall Rules

Databases (MySQL, PostgreSQL), file servers (NFS, Samba), and administrative services (VNC, SSH) should never be directly exposed on the network without firewall protection. Use firewall rules to restrict access to specific IPs and ports. Databases should only be accessible from the application server, not from the entire network. VNC and SSH should only be accessible from trusted management IPs.

Recommendation 5: Deploy Intrusion Detection and Regular Security Scanning

The Wireshark capture clearly showed that a port scan generates a very obvious pattern — hundreds of SYN packets in rapid succession. An IDS (Intrusion Detection System) like Snort or Suricata would have detected and alerted on this scan immediately. Deploy an IDS on the network. Run regular Nmap scans against your own systems to discover what is exposed before an attacker does. Review logs regularly for unusual connection patterns.

14. Challenges Faced

Challenge	What Happened	How It Was Resolved
service command not found on Metasploitable2	sudo service vsftpd stop did not work — Metasploitable2 uses an older init system where service command behaves differently	Used sudo /etc/init.d/vsftpd stop and then sudo kill -9 <PID> after finding the process with netstat
vsftpd managed by xinetd	vsftpd was not running as a standalone service but managed by xinetd (a super-server)	Found the xinetd PID using sudo netstat -tulnp grep :21 and killed the xinetd process
ProFTPD vs vsftpd	After killing xinetd, ProFTPD (port 2121) was still visible. Two FTP services were running.	Identified them separately. Port 21 (vsftpd via xinetd) was closed. Port 2121 (ProFTPD) is a separate service.
Wireshark showing large scan traffic	The Nmap SYN scan generated over 1,000 packets in Wireshark, making it hard to find specific packets	Used display filters (tcp.flags.syn == 1, tcp.flags.reset == 1) to isolate specific packet types

15. Conclusion

Week 3 was a comprehensive, hands-on network security assessment exercise. Starting from zero knowledge of what was on the network, a complete security assessment was performed using industry-standard tools (Nmap and Wireshark) on an authorized lab environment.

The key takeaways from this week are:

- Nmap is a powerful tool for discovering hosts, identifying services, detecting versions, and finding known vulnerabilities using NSE scripts.
- Wireshark allows a security analyst to see exactly what is happening on the network at the packet level — including port scan signatures, unencrypted credentials, and DNS queries.
- The Metasploitable2 target had multiple CRITICAL vulnerabilities — backdoors in vsftpd, a root bindshell, and UnrealIRCd — that would give an attacker complete control of the system.
- Security hardening was successfully applied: ports 21, 23, and 1099 were closed and verified with after scans.
- A real-world security assessment requires not just running tools, but analyzing results, understanding the risk, and implementing fixes — exactly what was done in this week's tasks.

This report demonstrates a complete security assessment cycle: Discovery → Analysis → Assessment → Hardening → Verification → Documentation. This is the same workflow used by professional penetration testers and security analysts in the real world.

16. References

#	Resource	URL
1	Nmap Official Website	https://nmap.org
2	Nmap Reference Guide	https://nmap.org/book/man.html
3	Nmap NSE Documentation	https://nmap.org/nsedoc/
4	Wireshark Official Website	https://www.wireshark.org
5	Wireshark User's Guide	https://www.wireshark.org/docs/wsug_html/
6	Wireshark Display Filter Reference	https://www.wireshark.org/docs/dfref/
7	MITRE ATT&CK Framework	https://attack.mitre.org
8	CVE Program	https://www.cve.org
9	CVE-2011-2523 — vsFTPD Backdoor	https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
10	CVE-2014-3566 — SSL POODLE	https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
11	Metasploitable2 Documentation	https://docs.rapid7.com/metasploit/metasploitable-2/

— End of Report —